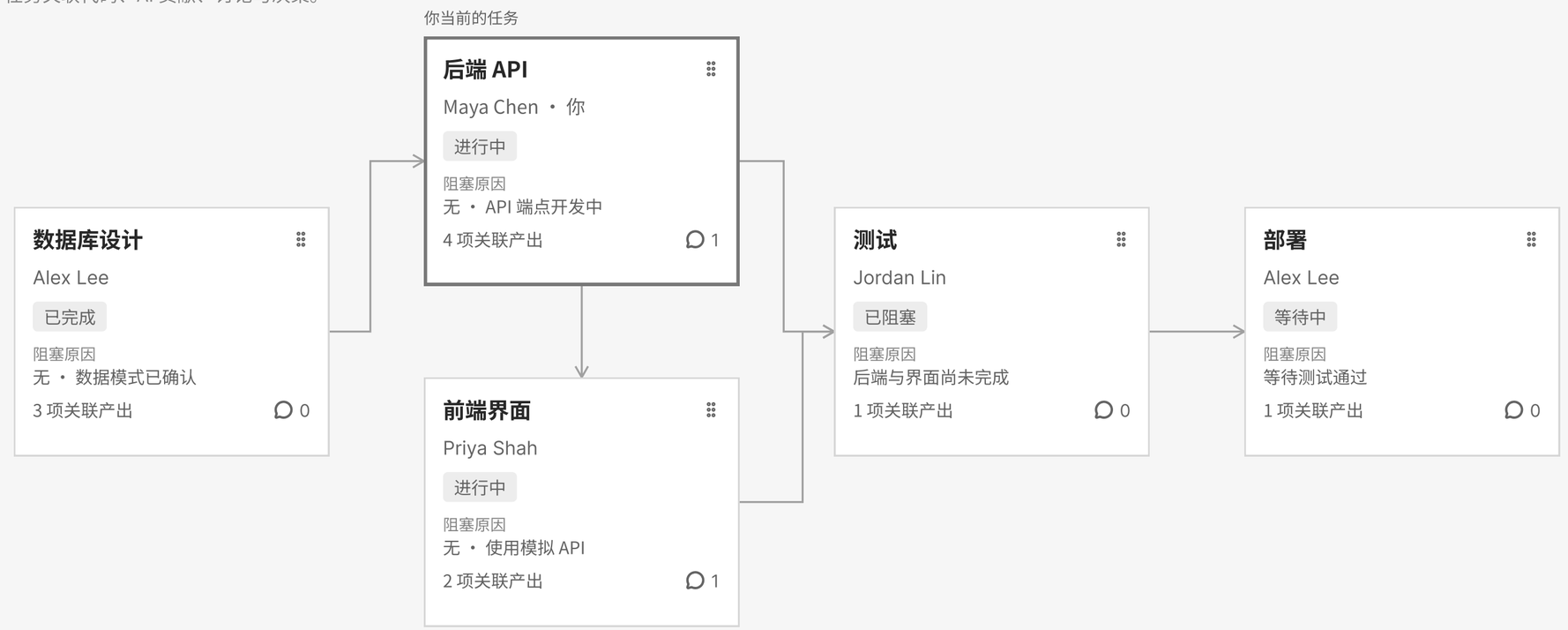
## 项目蓝图 5 项任务

+ 添加任务

任务关联代码、AI 贡献、讨论与决策。




前置任务 → 依赖任务　拖动调整位置 · 点击任务打开任务上下文层

− 100% + 适应画布

### 项目智能体

静默模式

提供项目理解所需的上下文。决策由团队作出。

静默建议

- 缺少 API 文档
  后端 API · 关联产出
- 测试任务依赖后端完成
  测试 ↔ 后端 API
- 两项技术讨论尚未解决
  API 错误处理 · 组件状态

从一个对象开始

打开任务，查看代码、AI 贡献及团队的思考过程。

仅提供建议，不会自动修改任务或决策。

### 你的协作空间

私密 · 仅你可见

当前任务
**后端 API**
审查 AI 生成的 API 端点

待处理讨论 · 2
**API 错误 · 组件状态**
等待你的意见

需要关注 · 1
**后端 API**
补充 API 文档

Maya Chen · 共享项目的个人视图，并非团队报告。

### 项目共享参考资料

快速访问

**人机协作约定**
角色分工与人工审查

**团队 AI 使用规范**
团队工作惯例

**项目验收标准**
完成标准

# 用户身份认证模块

进行中

**任务背景 · 为什么**

校园交易需验证学生身份，才能发布商品或联系卖家。

**任务目标 · 做什么**

实现安全的邮箱注册、登录和退出，保护路由并提供清晰的错误提示。

**验收标准 · 完成条件**

- ☐ 注册与登录正常；密码经哈希处理。
- ☐ 退出时结束会话；受保护路由拒绝访客。
- ☐ 异常场景通过测试，并经团队审查。

## 职责分工

主要负责人

MC **Maya Chen · 你**
身份认证 API 与人工代码审查

协作者

PS **Priya Shah**
登录界面与表单校验

JL **Jordan Lin**
会话测试与边界场景

当前权限

你：编辑代码、上下文与批注
团队：编辑产出、参与讨论
AI 智能体：仅提供建议，无审批权限

AI 辅助理解，团队验证代码并作出决策。

## 关联产出

4 个关联对象

代码文件 v0.3
**src/auth/session.ts**
登录、退出与会话守卫
AI 初稿 · Maya 正在审查差异
Maya Chen · 10月11日 · 14:20
打开代码与 AI 溯源层 →

文档 v0.2
**docs/auth-flow.md**
API 契约与 Cookie 使用依据
关联决策：采用服务端会话
Maya Chen · 10月10日 · 16:40
打开关联文档 →

设计文件 v0.2
**身份认证 / 登录与注册**
表单、字段错误与未登录状态
关联代码：src/auth/session.ts
Priya Shah · 10月11日 · 10:15
打开关联设计 →

测试记录 v0.3
**tests/auth-session.spec.ts**
10 项测试通过 8 项 · 过期场景待测
关联代码：src/auth/session.ts
Jordan Lin · 10月11日 · 13:50
打开关联测试记录 →

点击代码产出，查看代码、AI 贡献与人工审查。

## 待处理问题 / 批注

3 项待处理

点击批注 → 协作层

提问 · Jordan Lin 待处理
**会话过期时应返回 401，还是重定向?**
src/auth/session.ts · L48–62 讨论 →

建议 · Priya Shah 待处理
**邮箱不存在和密码错误时，使用相同的错误提示。**
src/auth/session.ts · L24–38 讨论 →

讨论 · Maya Chen 讨论中
**AI 初稿会在退出登录时清除 Cookie 吗?**
src/auth/session.ts · L70–82 讨论 →

已解决 · 讨论 · Alex Lee · 采用服务端会话，而非 JWT
src/auth/session.ts · L1–18 · 查看决策 →

## 任务演进

共享思考过程 · 决策仍由团队作出

**初步想法**
10月08日 · Maya Chen
学生登录后才能发布商品。
范围：邮箱注册、登录与退出。

→

**技术讨论**
10月09日 · 团队讨论
比较 JWT 与服务端会话。
审查 Cookie 安全性与 AI 的假设。

→

**决策**
10月10日 · 团队达成一致
采用 HttpOnly Cookie 与服务端会话。
Alex 将决策依据关联到 auth-flow.md。

→

**当前实现**
10月11日 · Maya Chen + 协作者
v0.3 AI 初稿正在人工审查。
退出登录与会话过期测试仍需验证。

# AI 产出理解层

只读审查

代码 ↔ AI 溯源 ↔ 讨论 ↔ 决策

## 项目产出

校园交易 / AUTH-01

**代码模块 · 3**

- **src/auth/session.ts** — v0.4 · 已选中待审查
- src/auth/routes.ts — 登录与受保护路由 · v0.3
- src/auth/password.ts — 密码哈希 · v0.2

**文档 · 2**

- docs/auth-flow.md — JWT 方案依据 · v0.3
- docs/api-contract.md — Bearer 令牌契约 · v0.2

**实验 · 2**

- 身份认证 API 测试记录 — API 测试通过 · v0.4
- 会话策略比较 — 服务端会话 → JWT

← 用户身份认证模块
查看任务上下文与验收标准

## src/auth/session.ts

只读 · TypeScript

### v0.3 服务端会话 → v0.4 JWT

统一差异对比 · − 删除 + 新增

L6–9 · 生成者：AI 智能体 · 决策者：Maya Chen · 验证者：Jordan Lin

```
1 +  import jwt from 'jsonwebtoken';
2    import bcrypt from 'bcrypt';
3    import { db } from '../db';
4
5    export async function login(email: string, password: string) {
6      const user = await db.user.findUnique({ where: { email } });
7      if (!user || !(await bcrypt.compare(password, user.hash))) {
8        throw new Error('Invalid credentials');
9      }
-      return sessions.create(user.id);
10 +    const token = jwt.sign(                                    [A]
11 +      { sub: user.id },
12 +      process.env.JWT_SECRET!,
13 +      { algorithm: 'HS256', expiresIn: '15m' }
14 +    );
15 +    return { accessToken: token, tokenType: 'Bearer' };
16   }
```

**[A] 已选中 · L10–14 · JWT 签发**

关联溯源记录与对象已高亮 →

生成者：AI 智能体　决策者：Maya Chen　验证者：Jordan Lin

为选中的产出 [A] 添加批注

提问　讨论　评估

**关联讨论 · [A] L10–14**

**前后端分离时采用 JWT?**

Priya：同意；在请求头中以 Bearer 方式发送令牌。

讨论 · Priya Shah + Maya Chen · 已解决

**关联决策 · [A] L10–14**

**已采纳 · 使用 JWT 身份认证**

适用于前后端分离架构

决策 · Maya Chen · 替代 v0.3 会话方案

## AI 协作溯源

关联到 [A]

**关联 AI 对话 · JWT 策略**

AUTH-01 / session.ts / v0.4 · 10月11日 · 14:35

**AI 输入 · 人类请求** [A] L10–14

**“为前后端分离的系统实现 JWT 登录。”**

保留密码校验，返回短期有效的访问令牌。

Maya Chen → AI 智能体

**AI 建议方案** [A] L10–14

**使用 JWT 身份认证**

对用户 ID 声明签名；向 API 发送 Bearer 令牌。

AI 智能体 · 仅提供建议，并非批准

**生成的产出** [A] L10–14

**JWT 签发 · src/auth/session.ts**

jwt.sign 使用 HS256，15 分钟后过期；返回 accessToken。

生成者：AI 智能体 · v0.4 · L10–14

**人工决策** [A] L10–14

**已采纳**

理由：适用于前后端分离架构

决策者：Maya Chen · 关联团队讨论

**验证** [A] L10–14

**API 测试通过**

登录返回 JWT，受保护 API 接受该令牌。无效或过期令牌返回 401。

验证者：Jordan Lin · 身份认证 API 测试记录 · v0.4

v0.4 修订了此前采用服务端会话的决策。
评估只针对产出，不针对团队成员。

# 协作与决策层

嵌入式 · 只读审查

AUTH-01 · 团队共享

任务 ↔ 代码 ↔ AI 产出 ↔ 讨论 ↔ 决策

## 项目产出

校园交易 / AUTH-01

**代码模块 · 3**

- **authentication.py** — v0.4 · 已选中待审查
- src/auth/routes.ts — 登录与受保护路由 · v0.3
- src/auth/password.ts — 密码哈希 · v0.2

**文档 · 2**

- docs/auth-flow.md — JWT 方案依据 · v0.3
- docs/api-contract.md — Bearer 令牌契约 · v0.2

**实验 · 2**

- 身份认证 API 测试记录 — 登录测试通过 · 过期场景待测
- 会话策略比较 — 服务端会话 → JWT

← 用户身份认证模块
查看任务上下文与验收标准

## authentication.py

只读 · Python

v0.3 服务端会话 → v0.4 JWT

AI 初稿 · 人工审查 · 查看 AI 溯源 →

```
1  from datetime import datetime, timedelta, timezone
2  import jwt
3  from config import JWT_SECRET
4
5  def login(email, password):
6      user = find_user(email)
7      if not user or not verify_password(password, user.password_hash):
8          raise InvalidCredentials("Invalid credentials")
9      now = datetime.now(timezone.utc)                          [A]
10     claims = {"sub": str(user.id), "iat": now,
11               "exp": now + timedelta(minutes=15)}
12     token = jwt.encode(claims, JWT_SECRET,
13                        algorithm="HS256")
14     return {"access_token": token, "token_type": "Bearer"}
15 # Protected routes verify signature and expiry before granting access.
```

**[A] L9–13 · JWT 签发 · 关联讨论 →**

生成者：AI 智能体 · 审查者：成员 A

### 移交负责权

任务 + 代码

**当前负责人**
成员 A · 身份认证 API

→

**新负责人**
成员 C · 选择

**已知问题**
退出登录不会撤销已签发的 JWT；令牌在过期前仍有效。

**剩余工作**
添加令牌撤销处理；测试过期令牌与受保护路由。

携上下文移交

代码、讨论与决策仍关联到 AUTH-01。

任务上下文：AUTH-01 · 用户身份认证模块
目标：安全登录、退出与受保护路由。

### 导师支持

请求导师审查

自动附带的上下文包

- ☑ **任务上下文** — AUTH-01 · 目标与验收标准
- ☑ **代码** — authentication.py · v0.4 · [A] L9–13
- ☑ **讨论历史** — JWT 讨论串 + 关联技术决策

## 关联讨论

关联到 [A]

[A] authentication.py · L9–13 · v0.4 — 团队已解决

提问 | 评估 | 讨论

评估针对产出，不针对个人。

### 为什么选择 JWT 而非会话?

**成员 A** 14:38
JWT 让独立前端调用多个 API，无需共享会话存储。

**成员 B** 14:40
退出登录时如何撤销令牌？被盗令牌在过期前可能仍可使用。

**AI 助手** 上下文摘要 · 14:41
API 契约采用 Bearer 令牌，此代码块设置了 15 分钟有效期。撤销问题尚未解决，团队需权衡取舍。

A、B、C 达成一致 · 后续事项保留在交接中 — 重新打开

↓ 转为技术决策记录 — 讨论解决后由团队执行；AI 不作决策。

### 技术决策记录

由成员 A 记录

**决策：使用 JWT 身份认证**

理由：支持分布式前端架构

参与者：A B C

来源：已解决的讨论 [A] · AUTH-01 · L9–13
修订此前采用服务端会话的决策 · 查看历史 →

# 项目记忆层

将协作经验沉淀为可复用的工程知识

搜索决策、问题、代码与经验… 当前项目 · ⌘K

试着搜索： 数据库优化 身份认证 模型训练

## 决策历史

从早到晚 · 每条记录均关联其依据

10月11日

### 身份认证策略 · 服务端会话 → JWT

人工决策 · 参与者：A B C

**问题：**独立前端客户端需调用多个 API，且不共享会话存储。

**讨论：**为什么选择 JWT 而非会话？比较共享会话与 Bearer 令牌；退出时撤销令牌的问题未解决。

**决策：**使用 JWT 身份认证

**理由：**支持分布式前端架构

任务 ↗
AUTH-01 · 用户身份认证模块

代码 ↗
authentication.py · v0.4 · L9–13

AI 对话 ↗
JWT 权衡摘要 [A]

验证记录 ↗
身份认证 API 测试记录
登录测试通过 · 过期场景待测

10月12日

### 退出登录时使令牌失效

后续事项示例 · 人工决策

**问题：**删除客户端令牌后，复制的 JWT 在过期前仍可使用。

**讨论：**比较仅靠过期失效的退出方案与令牌拒绝列表。团队优先考虑即时失效。

**决策：**受保护路由检查已撤销令牌的拒绝列表。

**理由：**确保退出登录的语义；记录仅保留至令牌过期。

任务 ↗
AUTH-02 · 令牌撤销

代码 ↗
src/auth/revocation.ts
拟议实现

AI 对话 ↗
令牌撤销方案 →

验证记录 ↗
退出登录后的重放测试
等待团队验证

10月12日

### 为商品列表查询添加索引

记录示例 · 人工决策

**问题：**按校区筛选在售商品时，会扫描整个商品表。

**讨论：**比较缓存与复合索引；EXPLAIN 显示筛选并排序的查询发生了表扫描。

**决策：**为 (campus_id, status, created_at) 添加索引。

**理由：**先匹配查询访问顺序，再引入缓存失效机制。

任务 ↗
DATA-03 · 数据库优化

代码 ↗
migrations/014_feed_index.sql

AI 对话 ↗
查询计划说明 →

验证记录 ↗
商品列表查询 EXPLAIN 记录
已使用索引 · 结果未改变

## 个人成长档案

[ 私密 ]

你的私密收藏 · 仅你可见。
用于学习笔记，并非团队评价。

**参与的重要技术决策**
比较 JWT 与会话，讨论无状态身份认证的代价。
↳ 身份认证策略 · AUTH-01

**已解决的问题**
从筛选顺序定位商品表扫描原因，检查复合索引的执行计划。
↳ 为商品列表查询添加索引 · DATA-03

**实践的技能**
设计退出登录后的重放测试，检验令牌过期机制的局限。
↳ 令牌撤销 · AUTH-02

## AI 生成的项目总结

总结初稿 · 基于可见的决策记录

**AI 提供了哪些帮助**
解释 JWT 的权衡，列出令牌撤销方案，解读商品列表查询计划。

**人类作出了哪些决策**
A B C 选择了 JWT。团队选择拒绝列表检查与查询索引，验证仍由人类负责。

**重要工程经验**
无状态令牌仍需退出登录策略。添加缓存前，应检查查询的访问模式。

JWT 过期验证仍待完成。
通过关联依据追溯每项经验 →

# 个人 AI 工作区

默认私密

AUTH-01 上下文 • 个人草稿 • 未发布

仅你可见 • 不会自动同步

## 文件资源管理器

+ ···

v campus-exchange • 本地

v src / auth

- session.ts M
- routes.ts
- password.ts

v docs

- auth-flow.md M

v tests

- auth-session.spec.ts M

你的文件 • 可编辑

基于团队版本 v0.4
团队决策：使用 JWT 身份认证

session.ts ● | auth-session.spec.ts ×

可编辑 • TypeScript | 保存到本地

src/auth/session.ts • 基于团队 v0.4 的个人 v0.5 草稿 | AI = AI 生成 • 你 = 人工修改

```
1  import jwt from 'jsonwebtoken';
2  import bcrypt from 'bcrypt';
3  import { db } from '../db';
4
5  export async function login(email: string, password: string) {
6    const user = await db.user.findUnique({ where: { email } });
7    if (!user || !(await bcrypt.compare(password, user.hash))) {
8      throw new Error('Invalid credentials');
9    }
10   const secret = process.env.JWT_SECRET;                          AI
11   if (!secret) throw new Error('Auth configuration missing');     你
12   const token = jwt.sign(                                         AI
13     { sub: user.id }, secret,                                     你
14     { algorithm: 'HS256', expiresIn: '15m' }                      AI
15   );
16   return { accessToken: token, tokenType: 'Bearer' };
17 }
18 // Next: verify configuration and token expiry cases              你
```

▷ 运行测试 • 本地：3/3 守卫测试通过 • Maya 已验证 | 待团队审查 • 行 11，列 59

## AI 智能体

私密对话

生成代码 | 解释代码 | 调试错误 | 重构 | 探索方案

交互记录 • JWT 配置校验 • AUTH-01

**用户请求** session.ts
为 JWT 登录添加密钥缺失校验，保留团队设定的 15 分钟令牌有效期。
Maya Chen → AI 智能体 • 14:42

**AI 回复** session.ts
签名前检查 JWT_SECRET，未配置时明确报错。保留 HS256 与现有有效期。
AI 建议 • 由你决定是否应用

**生成的代码** session.ts
session.ts • L10–14 • 密钥校验 + JWT 签发
AI 生成的初稿 • Maya 已在本地应用

**修改历史** session.ts
AI：添加校验 → 你：明确错误提示并使用已验证的密钥 → 你：运行 3 项守卫测试。
个人 v0.5 • 已经人工审查 • 未发布

询问这段代码… 发送 ↑

## 个人探索笔记

私密 • 绝不包含在本次发布中

**JWT 校验 • 草稿笔记**

- 失败尝试：非空断言掩盖了配置缺失。
- 保留 JWT；以后比较刷新策略。
- 下一步：检查退出与撤销的边界场景。

已私密保存 • Maya Chen • 14:49

## 向团队发布所选成果

私密草稿 → 共享项目对象

预览 • 未发布

**共享 • 所选项目将对外发布**

- [x] 代码
- [x] AI 推理过程
- [x] 技术决策
- [x] 验证记录

v0.5 校验 + 理由 + Maya 的审查 + 本地 3/3 测试记录

**保持私密 • 不发布**

- [x] 失败尝试
- [x] 探索过程

在此勾选表示私密保留，而非共享。笔记仍仅你可见。

**发布后，系统将创建：**

**关联任务**
AUTH-01 • 用户身份认证模块

**职责信息**
AI：初稿 • Maya：决策与本地验证

**AI 协作溯源**
请求 → 推理 → 代码 → 人工修改 → 测试
关联任务 + 文件 + 版本，而非堆砌聊天记录。

**发布到校园交易 • 团队项目**

基于“使用 JWT 身份认证”的决策。Maya 保留校验逻辑；此草稿仍待团队审查。

发布所选项目

仅由你触发发布。目前尚未共享任何内容，也不会自动同步。